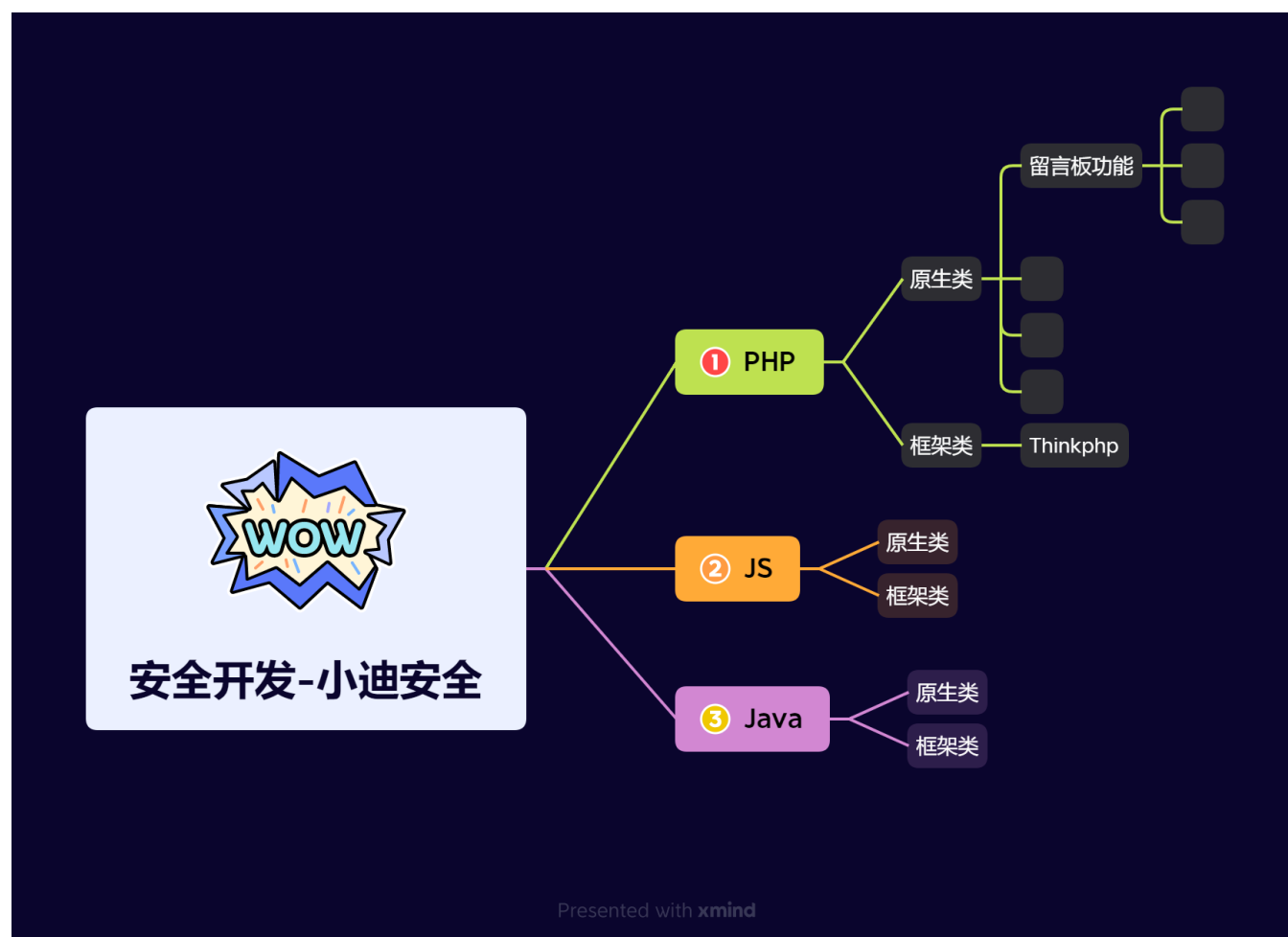


Day26 安全开发-PHP应用&模版引用&Smarty渲染&MVC模型&数据联动&RCE安全



1.知识点

- 1、PHP留言板前后端功能实现
- 2、数据库创建&架构&增删改查
- 3、内置超全局变量&HTML&JS混编
- 4、第三方应用插件&传参&对象调用

-
- 1、PHP后台身份验证模块实现
 - 2、Cookie&Session技术&差异
 - 3、Token数据包唯一性应用场景
 - 项目1：用cookie做后台身份验证
 - 项目2：用session做后台身份验证
 - 项目3：用token做用户登录判断
-

- 1、PHP文件管理-显示&上传功能实现
 - 2、文件上传-\$_FILES&过滤机制实现
 - 3、文件显示-目录遍历&过滤机制实现
-

- 1、PHP文件管理-下载&删除功能实现
 - 2、PHP文件管理-编辑&包含功能实现
-

- 1、PHP新闻显示-数据库操作读取显示
 - 2、PHP模版引用-自写模版&Smarty渲染
 - 3、PHP模版安全-RCE代码执行&三方漏洞
-

2.演示案例

2.1 新闻列表&模版引用-代码RCE安全



- 1 #新闻列表
- 2 1、数据库创建新闻存储
- 3 2、代码连接数据库读取
- 4 3、页面进行自定义显示



- 1 #自写模版引用
- 2 1、页面显示样式编排
- 3 2、显示数据插入页面
- 4 3、引用模版调用触发



- 1 #Smarty模版引用
- 2 下载: <https://github.com/smarty-php/smarty/releases>
- 3 使用:
- 4 1、创建一个文件夹, 命名为smarty-demo。
- 5 2、下载Smarty对应版本并解压缩到该文件夹中。
- 6 3、创建一个PHP文件, 命名为index.php, 并在文件中添加以下代码:
- 7 <?php
- 8 // 引入 Smarty 类文件
- 9 require('smarty-demo/libs/Smarty.class.php');
- 10 // 创建 Smarty 实例
- 11 \$smarty = new Smarty;
- 12 // 设置 Smarty 相关属性
- 13 \$smarty->template_dir = 'smarty-demo/templates/';
- 14 \$smarty->compile_dir = 'smarty-demo/templates_c/';
- 15 \$smarty->cache_dir = 'smarty-demo/cache/';

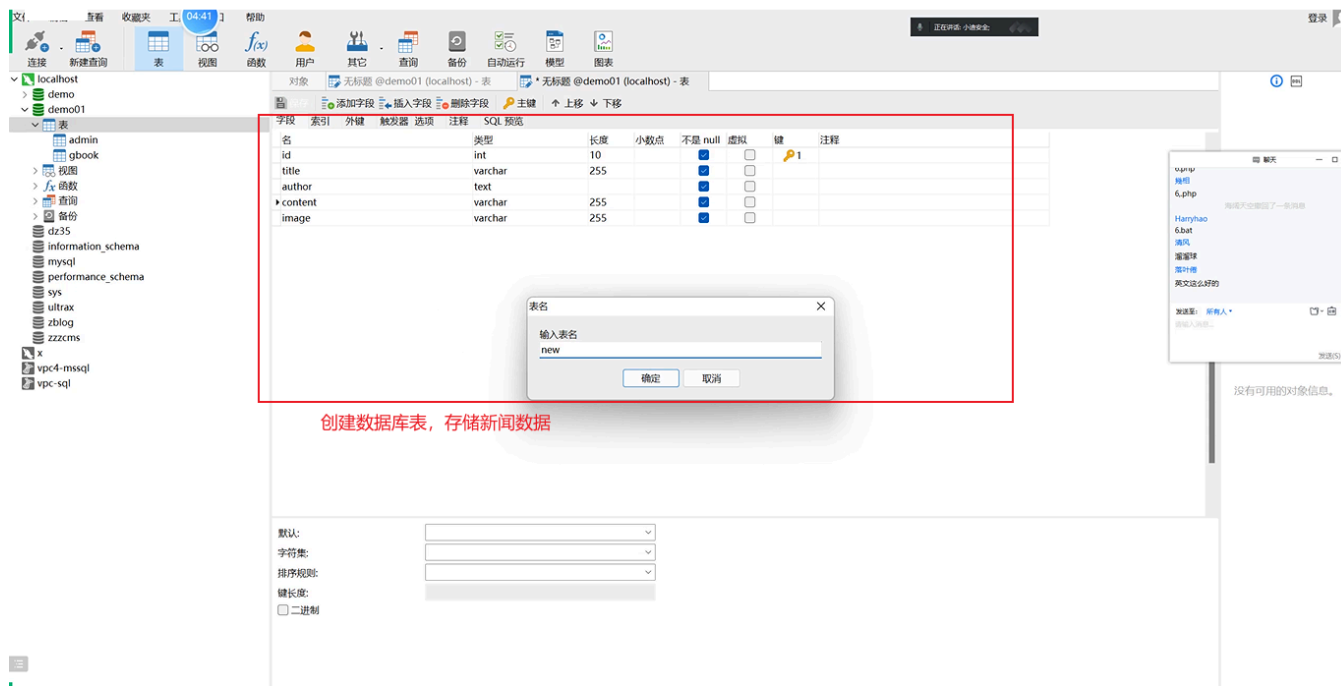
```

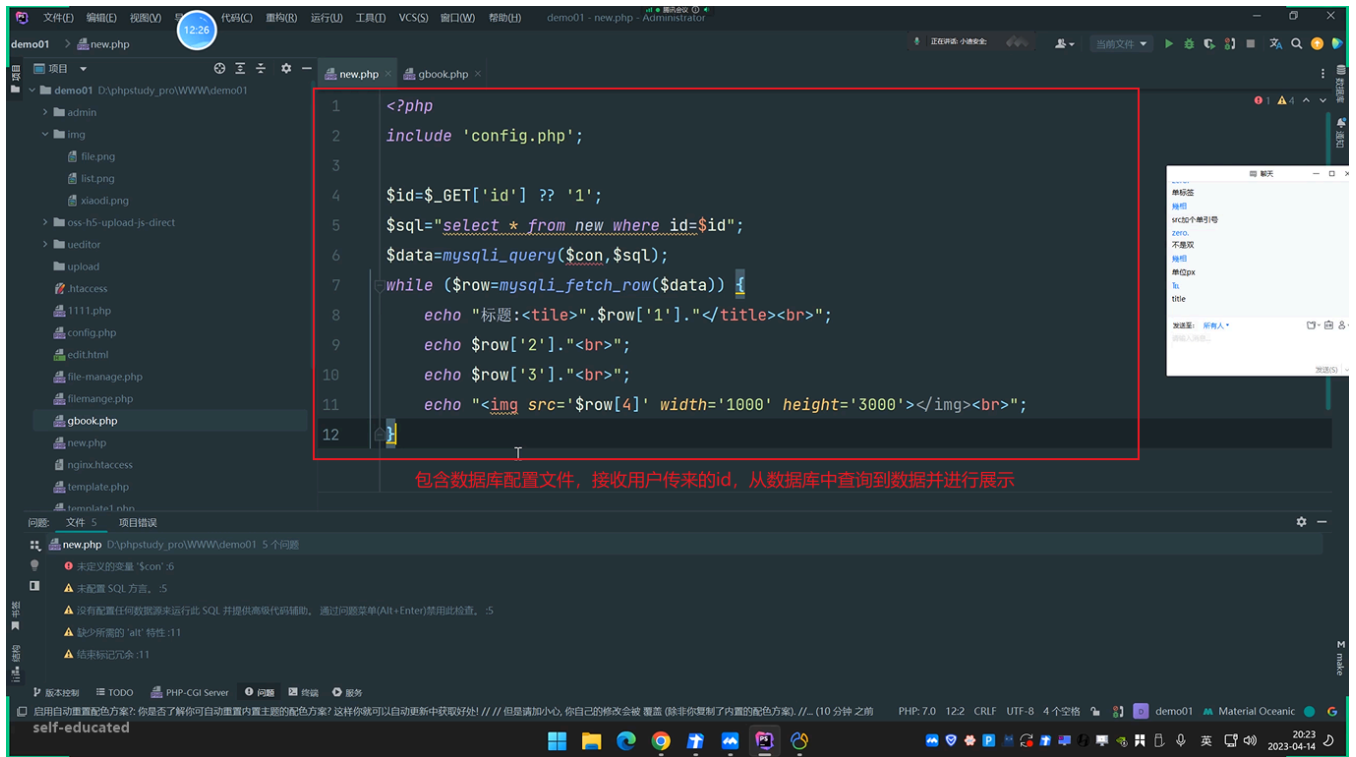
16 $smarty->config_dir = 'smarty-demo/configs/';
17 // 赋值变量到模板中
18 $smarty->assign('title', '欢迎使用 Smarty');
19 // 显示模板
20 $smarty->display('index.tpl');
21 ?>
22 4、创建一个名为index.tpl的模板文件，并将以下代码复制到上述点定义文件夹中
23 <!DOCTYPE html>
24 <html>
25 <head>
26 <title>{$title}</title>
27 </head>
28 <body>
29 <h1>{$title}</h1>
30 <p>这是一个使用 Smarty 的例子。</p>
31 </body>
32 </html>

```

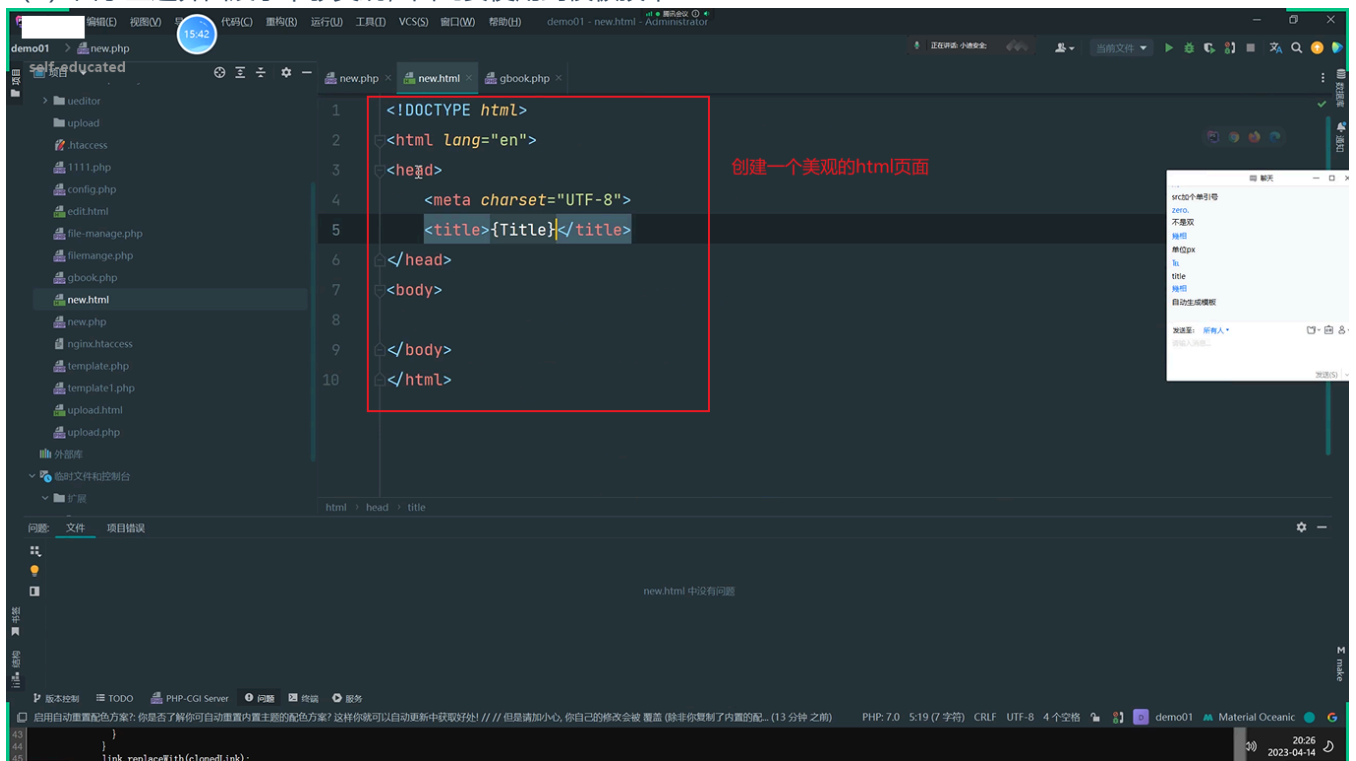
- 1 #代码RCE安全测试
- 2 1、自写模版的安全隐患
- 3 2、第三方Smarty的安全隐患

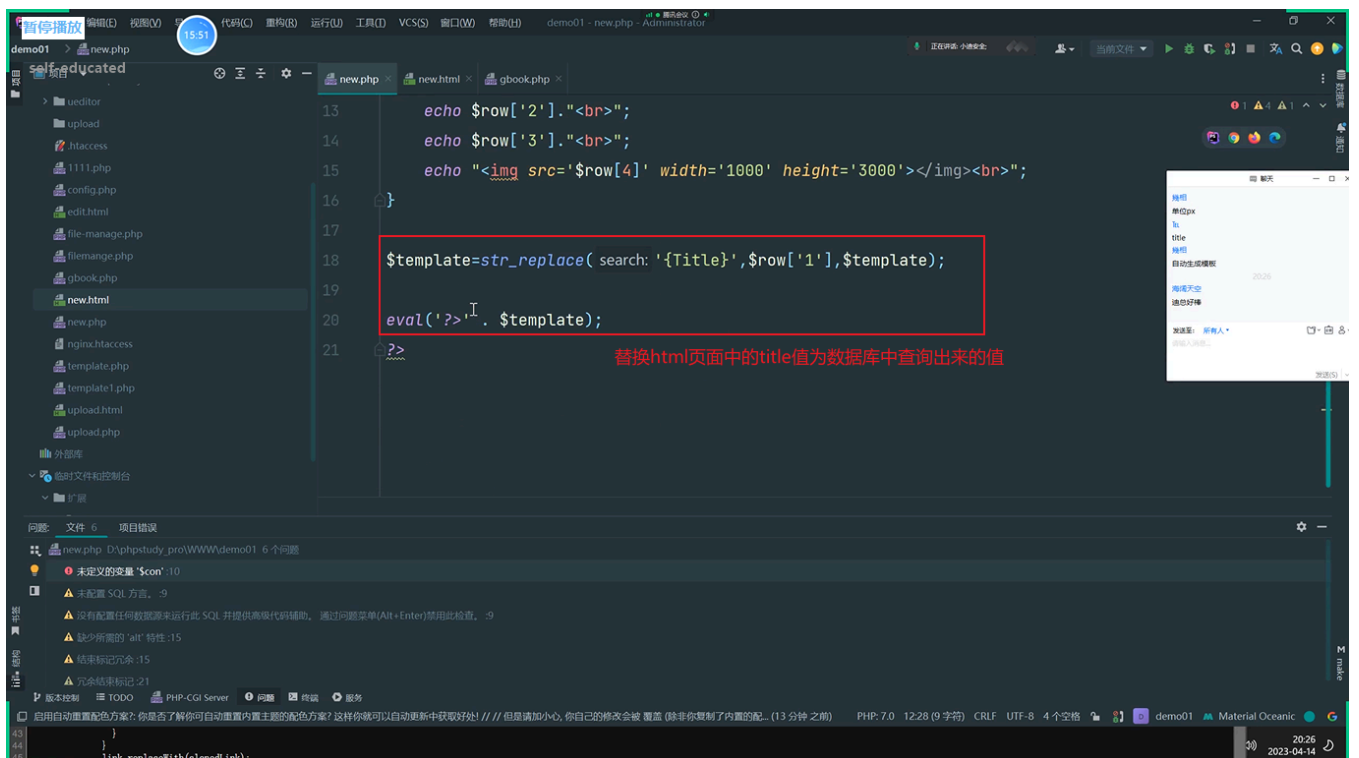
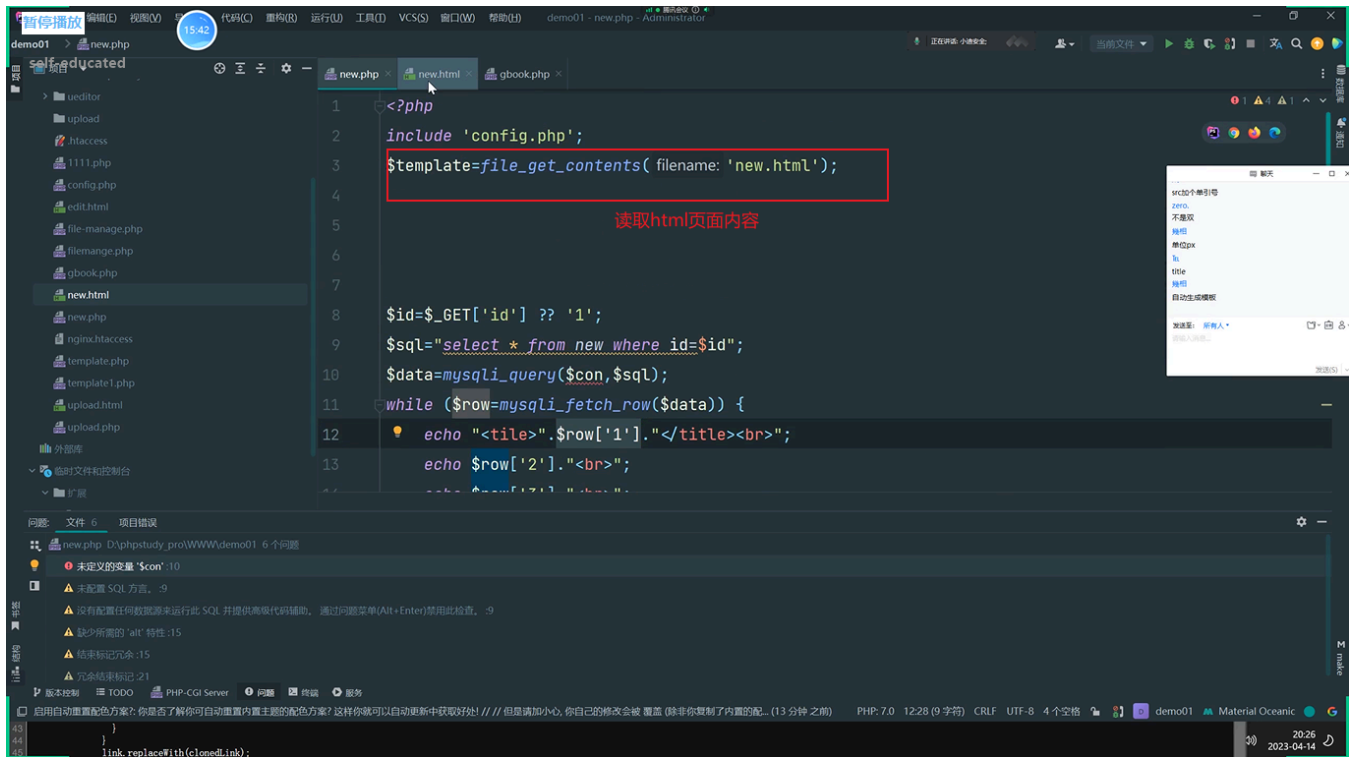
(1) 创建新闻列表:

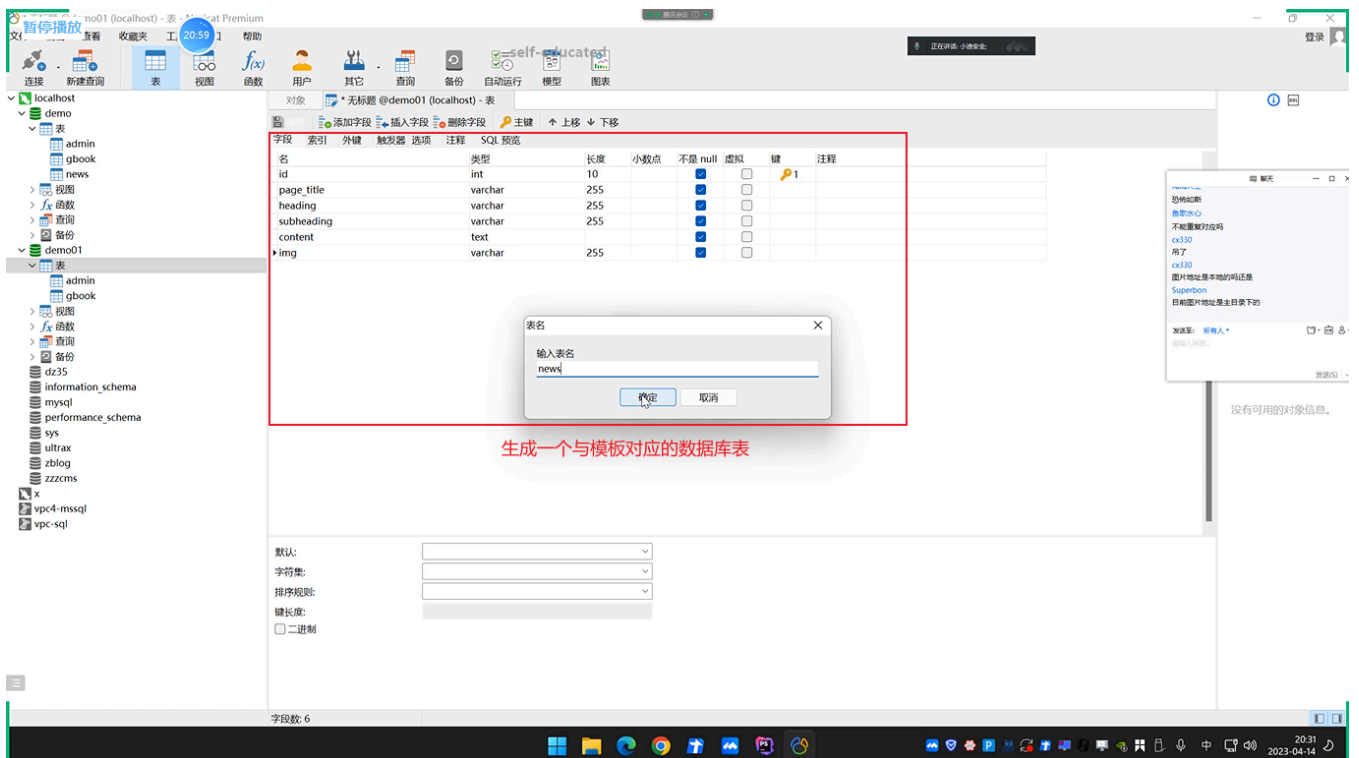
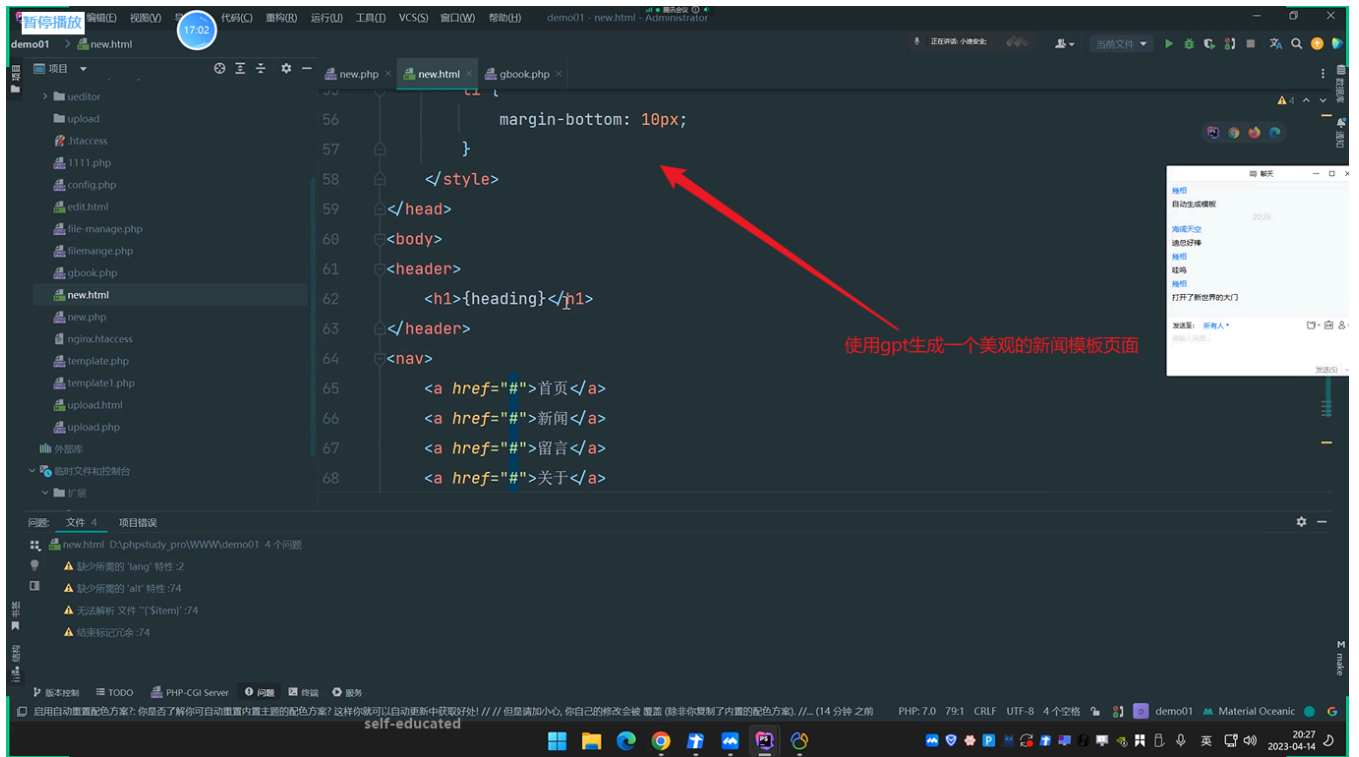


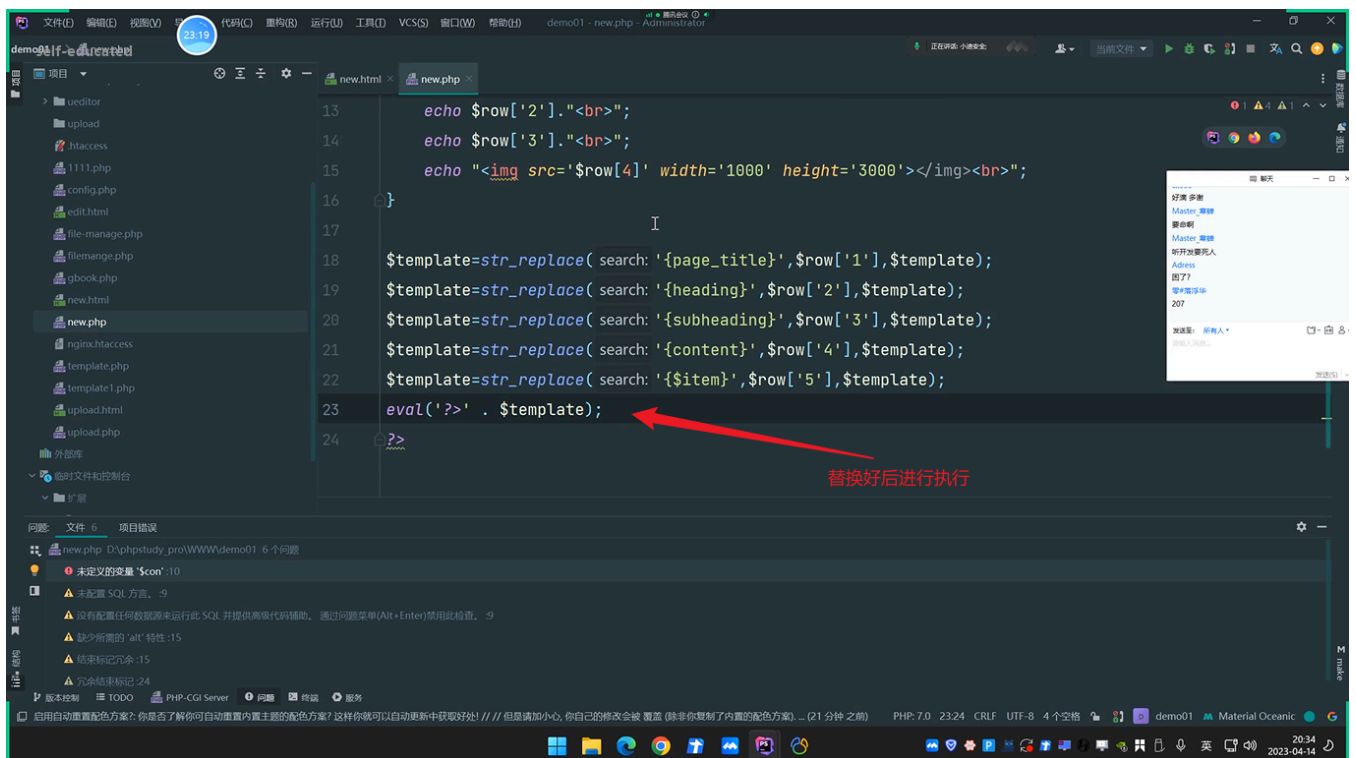
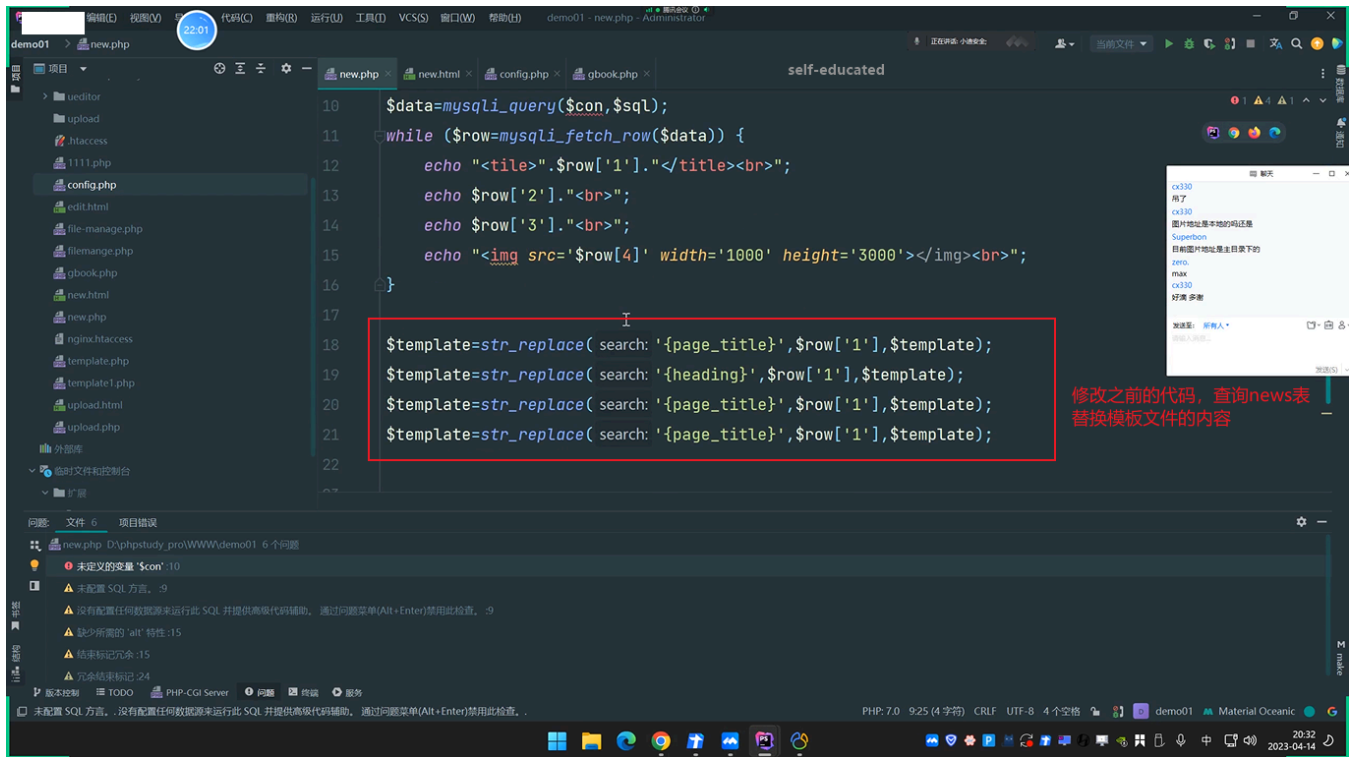


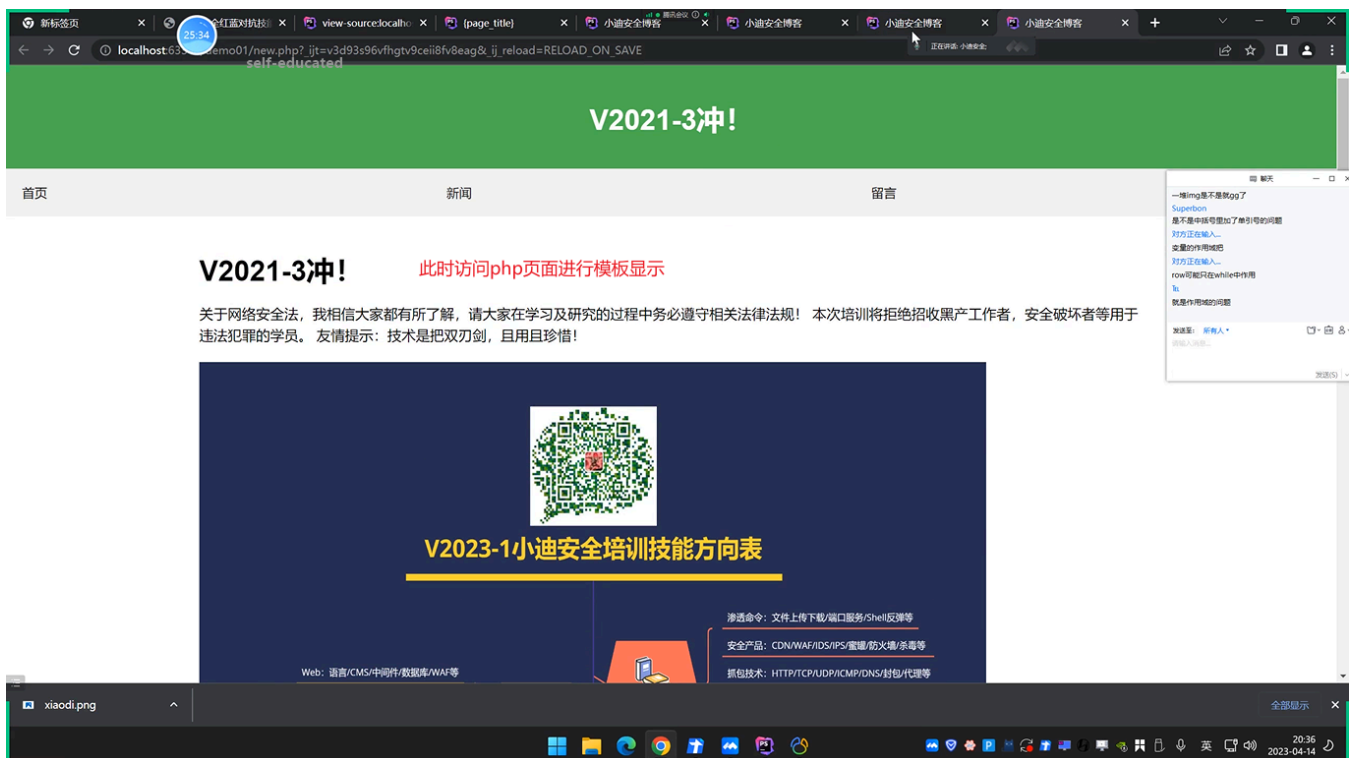
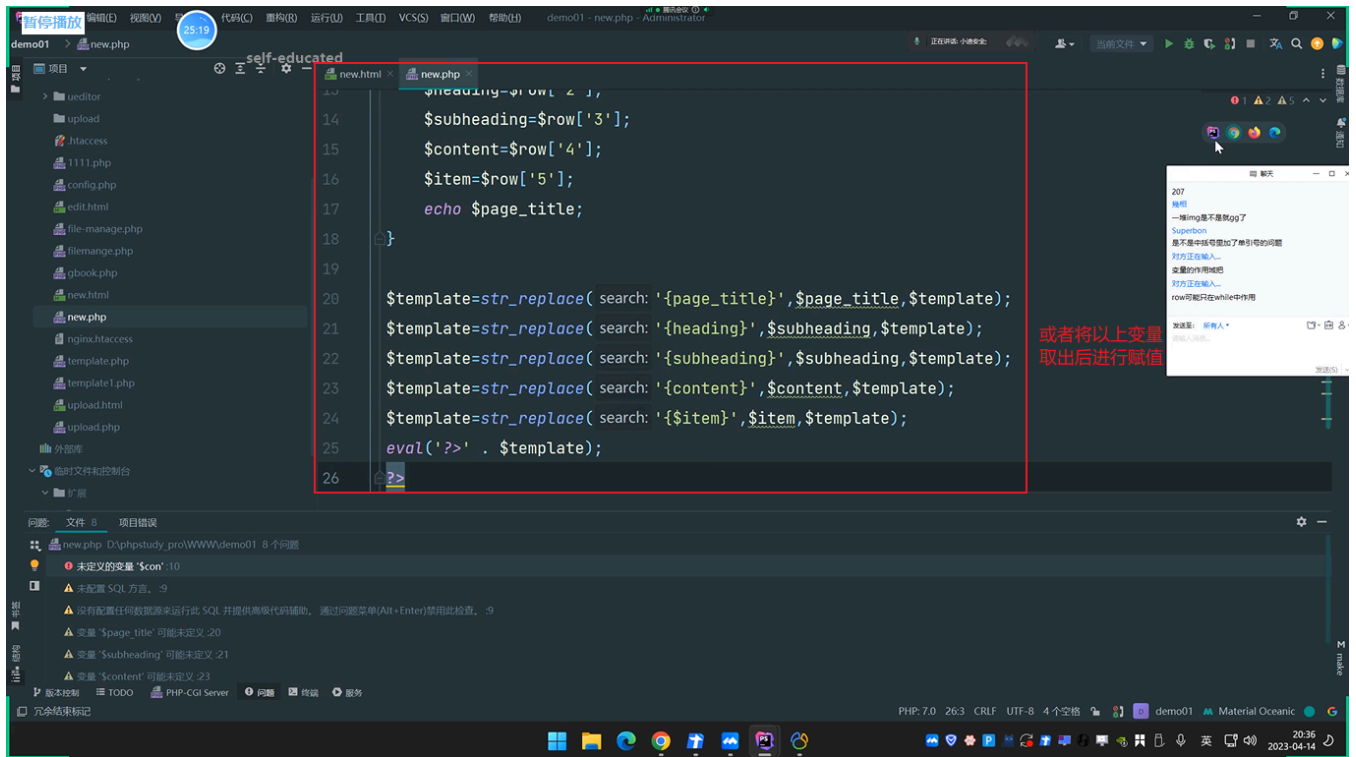
(2) 由于上述界面展示不够美观, 因此要使用到模板技术:



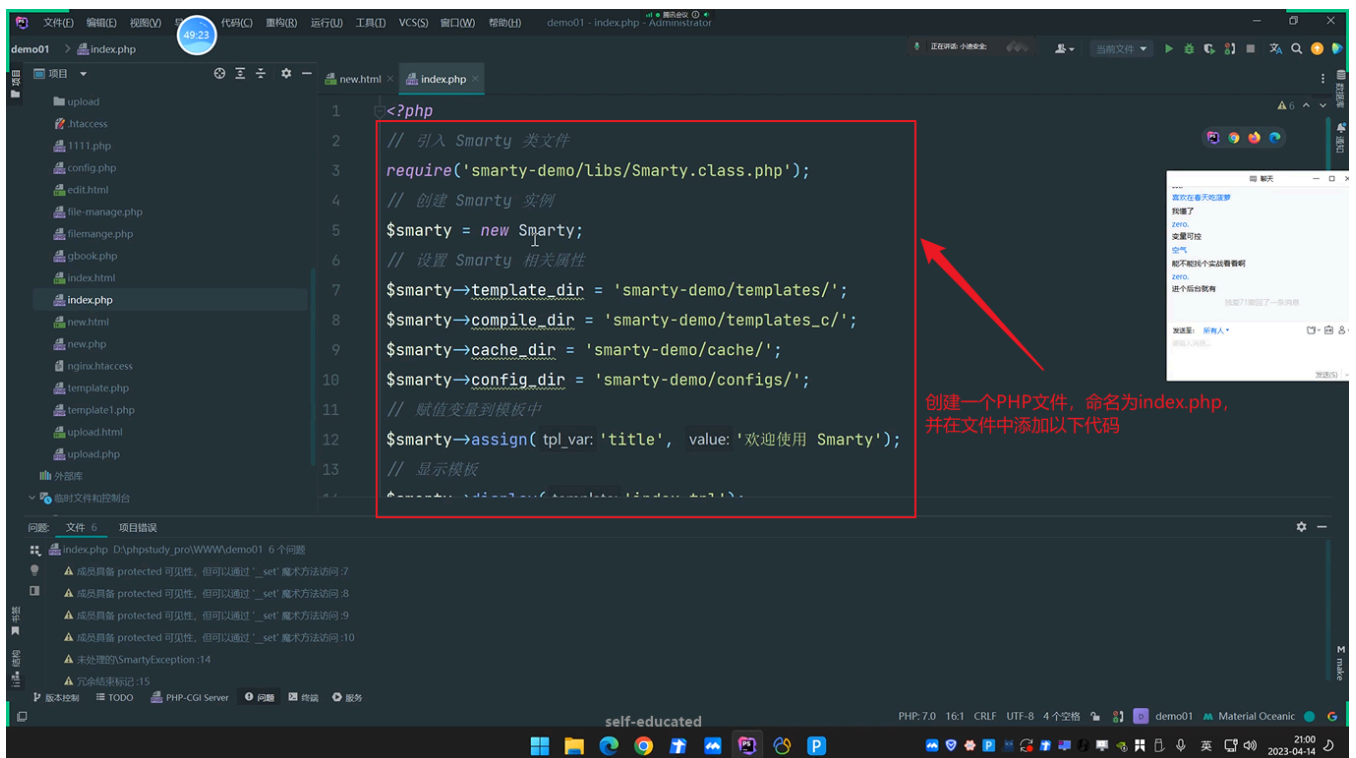
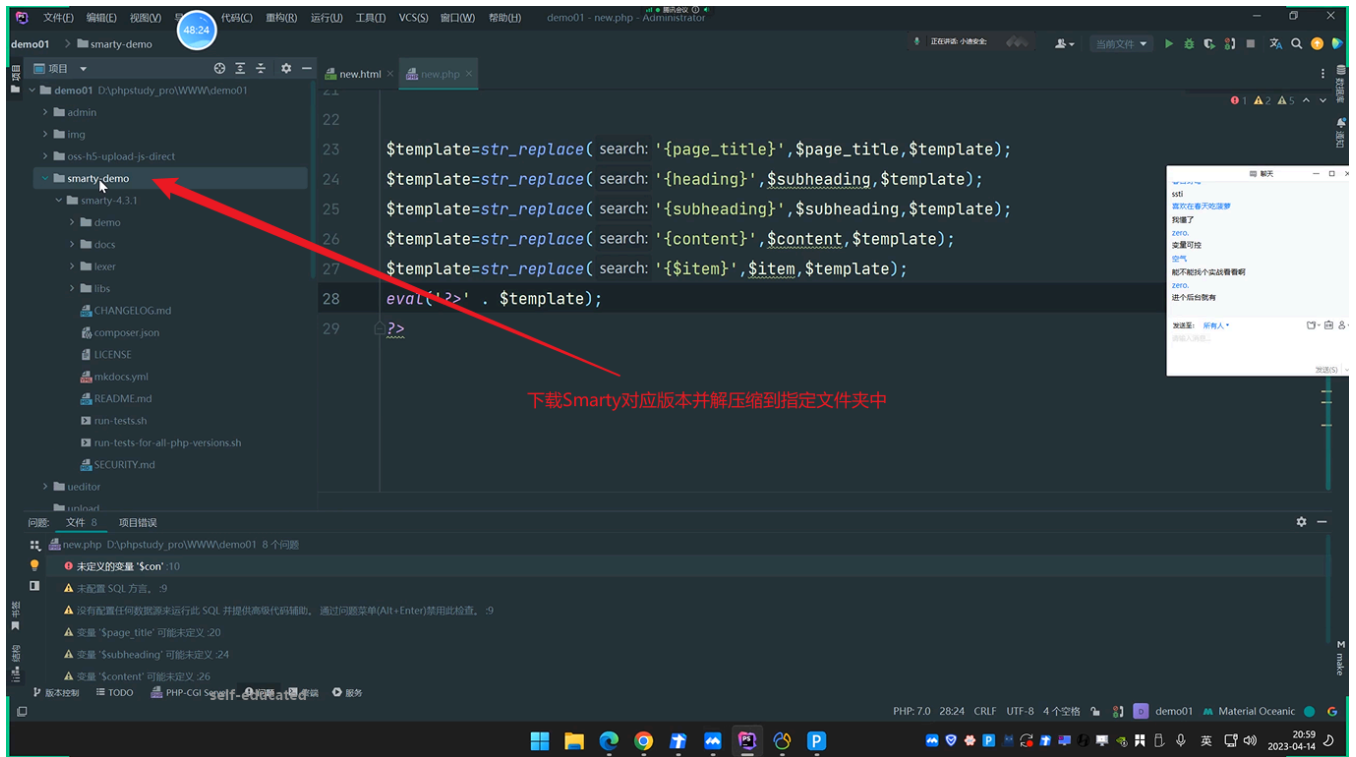


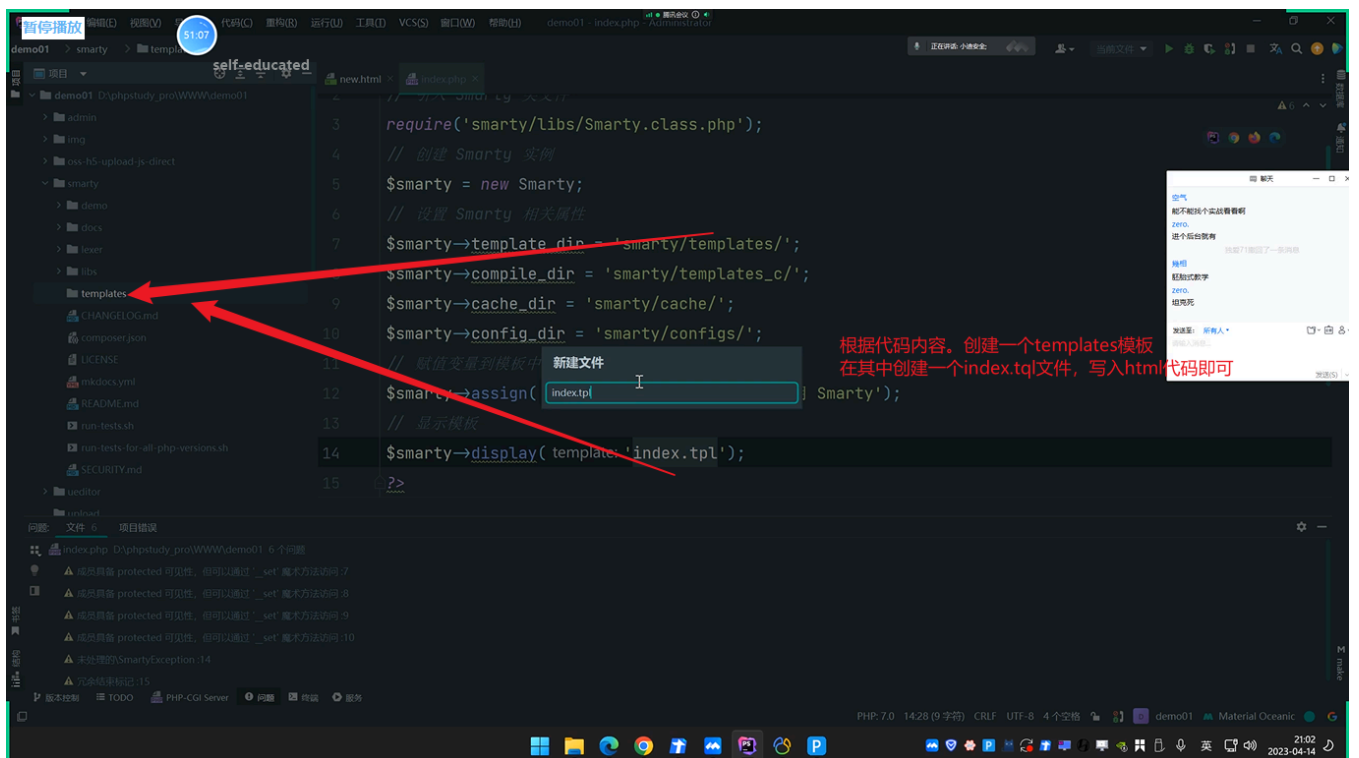
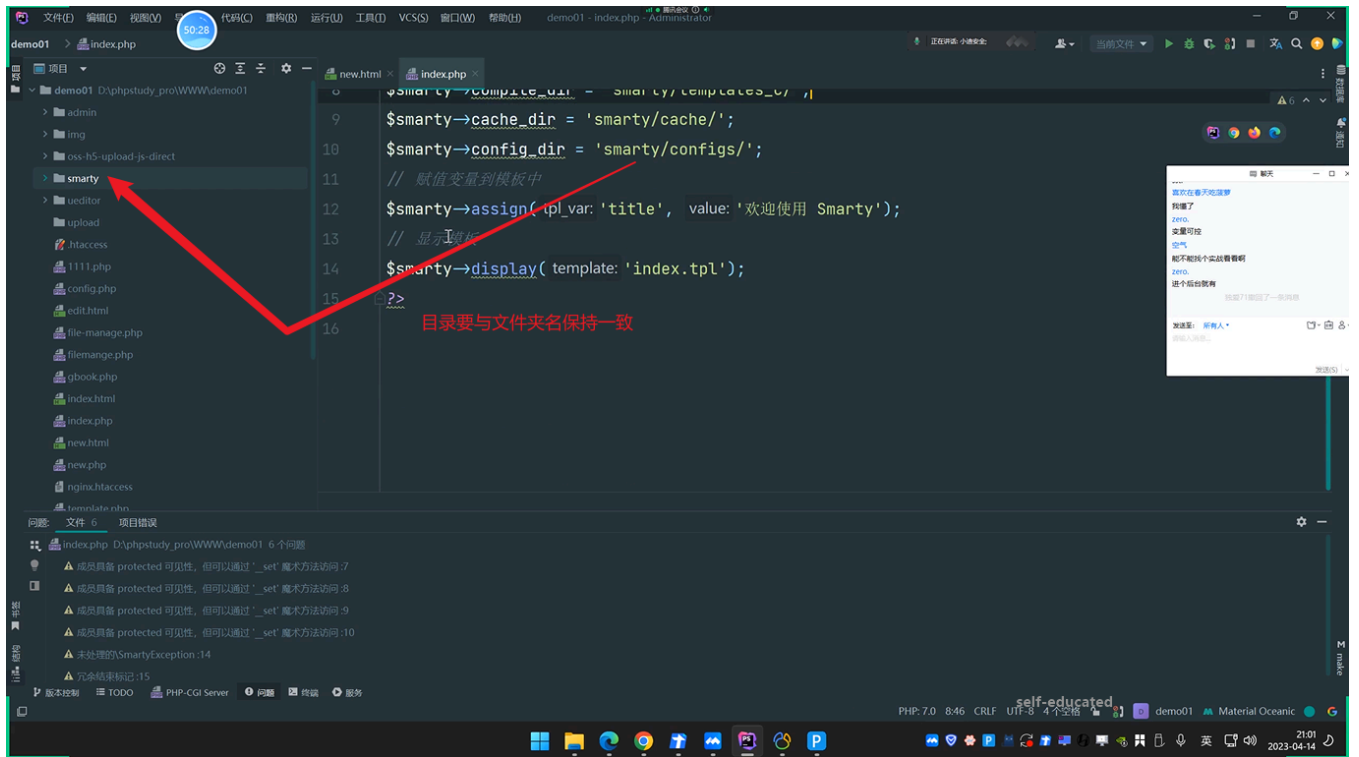


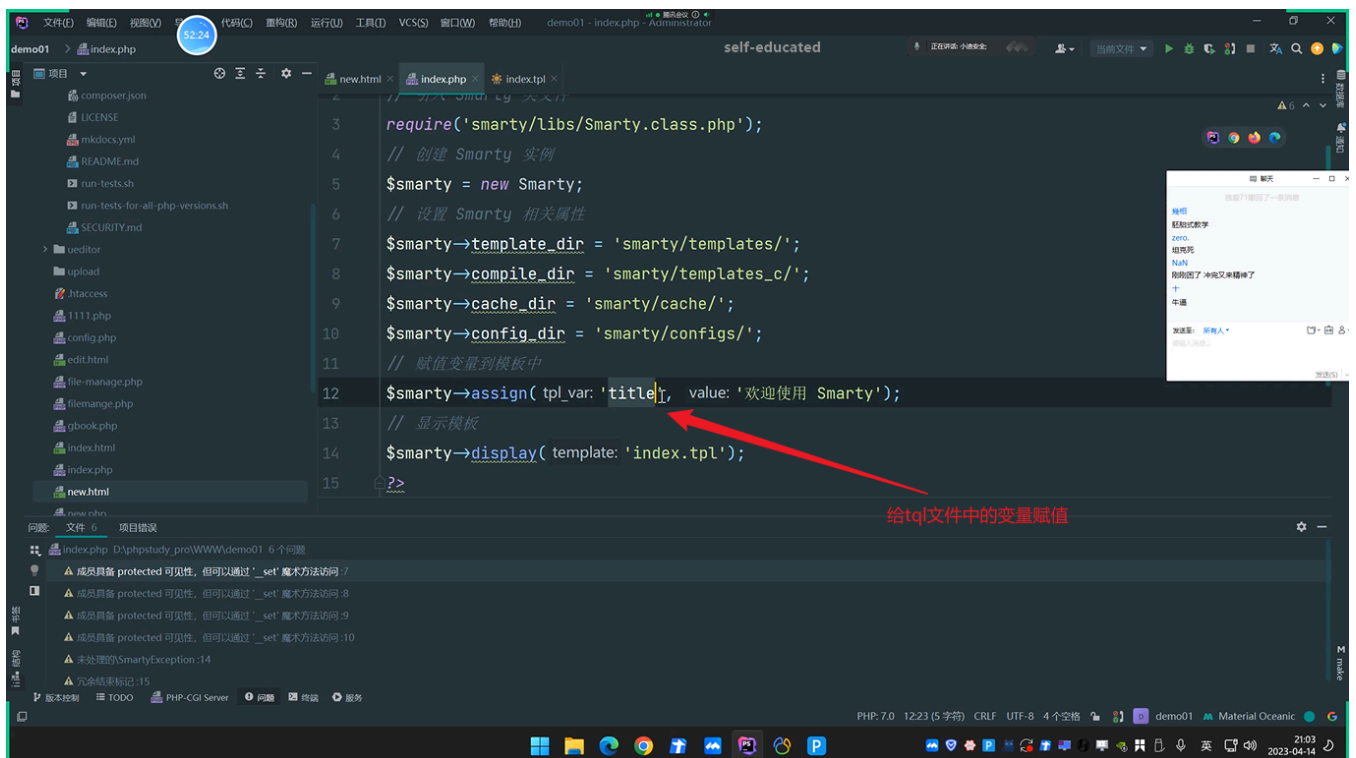
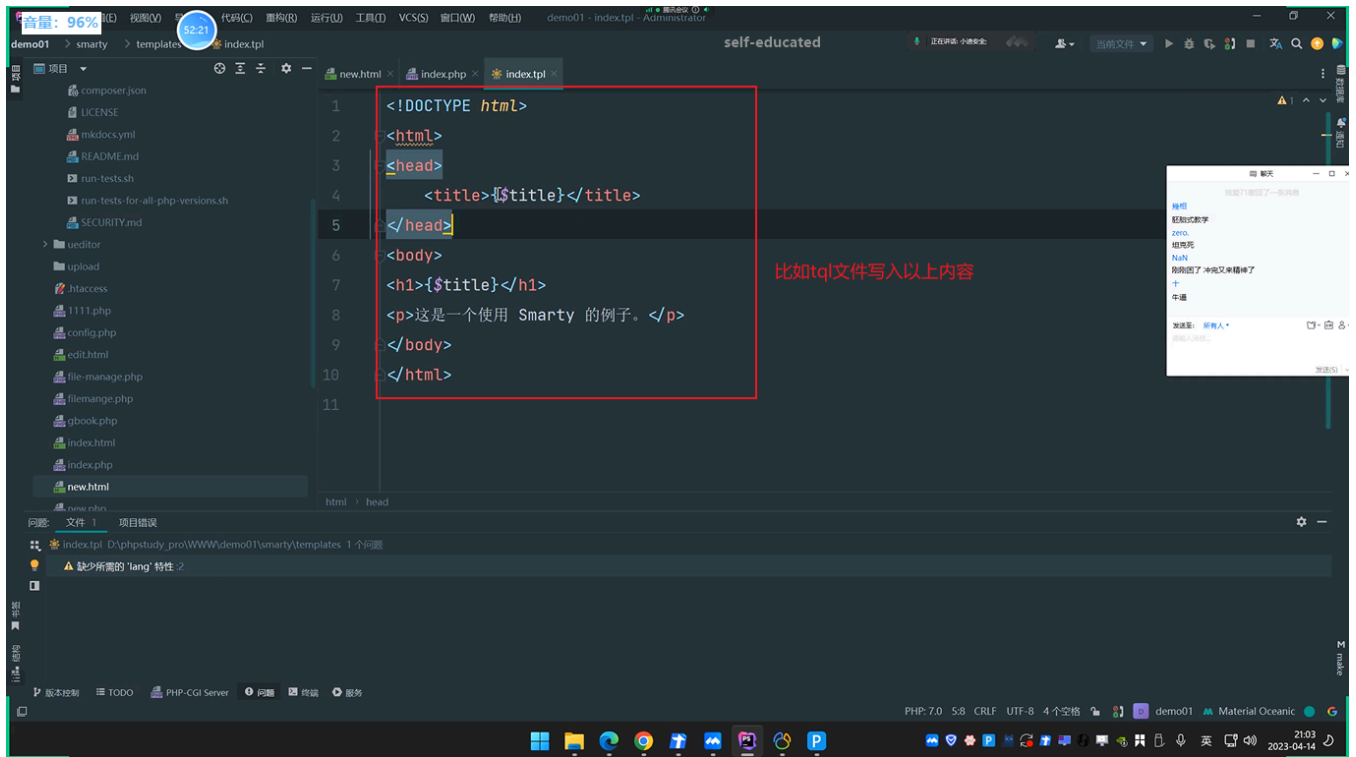


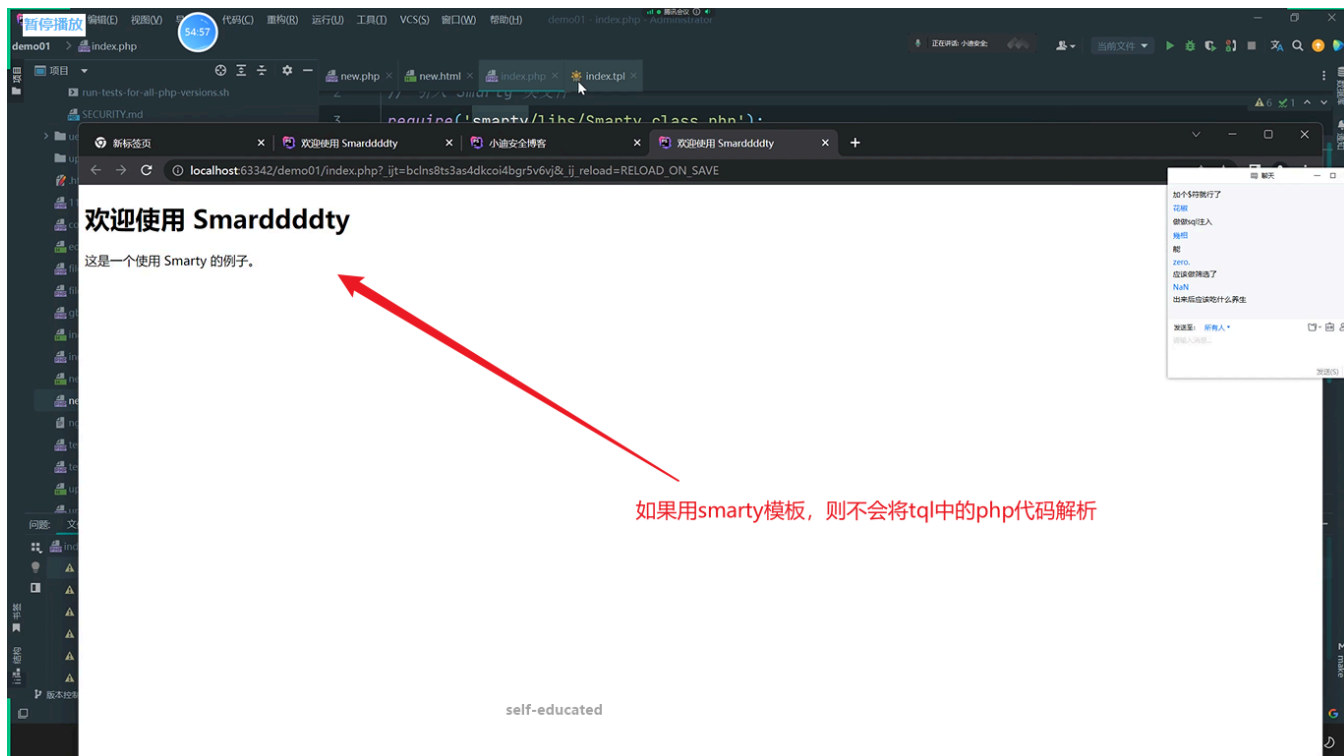


(3) Smarty模板引用：









1 smarty也并不是绝对安全, 也爆过相关漏洞, 网上查询利用即可。